Lab 28 — Vulnerability Management Pipeline with Trivy

You will scan an OS, a filesystem, and a container image with Trivy, then export findings as a CVSS-prioritised report.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt + binary): - `trivy` - `docker.io` (optional, for the image scan)

Step 1 — Install Trivy

```
apt update && apt install -y wget gnupg
wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | gpg --dearmor > /usr/share/keyrings/trivy.gpg
echo "deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb generic main" \
  > /etc/apt/sources.list.d/trivy.list
apt update && apt install -y trivy
```

```
trivy --version
```

Step 2 — Scan the running OS

```
trivy rootfs --scanners vuln --severity HIGH,CRITICAL / 2>/dev/null |
tail -40
```

This walks every installed package and matches it against the NVD / Ubuntu Security Tracker.

Step 3 — Export to JSON for the SIEM

```
trivy rootfs --severity HIGH,CRITICAL --format json -o trivy.json /

jq '[.Results[].Vulnerabilities[]? | {pkg:.PkgName,
cve:.VulnerabilityID, sev:.Severity, fix:.FixedVersion}] |
unique_by(.cve) | length as $c | "Total unique CVEs: \($c)"'
trivy.json
```

Step 4 — Scan a container image

```
apt install -y docker.io && systemctl start docker

docker pull node:14-alpine
```

```
trivy image --severity HIGH,CRITICAL node:14-alpine 2>/dev/null |
head -30
```

The deliberately-old `node:14-alpine` will surface dozens of fixed vulns.

Step 5 — Build a remediation queue (CVSS-sorted)

```
trivy image --format json node:14-alpine 2>/dev/null \
 | jq -r '.Results[].Vulnerabilities[]? |
[.VulnerabilityID, .Severity, (.CVSS.nvd.V3Score //
0), .PkgName, .FixedVersion // "no-fix"] | @tsv' \
 | sort -k3,3 -nr | head -10
```

Sort by CVSS v3 base score → top 10 patch list.

Step 6 — Detect secrets in the codebase

```
mkdir -p src && echo 'AWS_SECRET="AKIAIOSFODNN7EXAMPLE"' > src/.env
trivy fs --scanners secret src/
```

Trivy doubles as a secret-scanner — this is your last-line defence before pushing to git.

Free online tools

- **NVD CVE search** — https://nvd.nist.gov
- **Ubuntu Security Tracker** — https://ubuntu.com/security/cves
- **GitHub Security Advisories** — https://github.com/advisories
- **OSV.dev** (open-source vuln DB) — https://osv.dev
- **Snyk free tier** — https://snyk.io
- **CVSS calculator** — https://www.first.org/cvss/calculator/3.1

What you learned

- Three Trivy modes: rootfs, image, fs (each is one command).
- How to convert raw scan output into a CVSS-sorted patch backlog.
- That the same scanner finds both CVEs and secrets — fold it into CI.